

セキュリティチェック報告書

生成元: docs/security-check.md | 生成日時: 2026/04/27

セキュリティチェック報告書

1. 実施概要

- 対象アプリ: かわいい家計簿 / kakeibo-app
- 本番 URL: <https://kawaii0214.vercel.app>
- ドキュメント更新日: 2026-04-27
- 直近の検証結果反映日: 2026-04-27
- 実施範囲: 依存パッケージ監査、ビルド検証、静的シークレット検査、API 防御状況の確認、コードセキュリティレビュー（ブランチ kawaii0214）

2. 数値サマリー

- セキュリティ総合評価: 93%
- npm audit 脆弱性件数: 0
- Critical: 0
- High: 0
- Moderate: 0
- Low: 0
- Git 管理下のハードコード秘密情報検出件数: 0
- Git 管理下の .env 系ファイル件数: 1
- 管理対象の .env 系ファイル: .env.example のみ
- POST API ルート数: 17
- same-origin 防御あり: 16 / 17
- rateLimit 適用あり: 7 / 17
- ビルド失敗件数: 0

- 非ブロッキング build warning 件数: 3 (依存由来: @auth0/nextjs-auth0 × 1、jose Edge Runtime × 2)
- TypeScript エラー件数: 0
- ESLint エラー / 警告件数: 0

3. 総合評価の算出方法

- 今回の総合評価は、静的検査とビルド検証の結果を 100 点満点で重み付けして算出
- 依存脆弱性: 30 / 30
- シークレット管理: 25 / 25
- リクエスト起点保護: 18.8 / 20
- レート制限: 4.1 / 10
- 品質ゲート: 15 / 15
- 合計: 92.9 / 100 → 四捨五入して 93%

4. 実施コマンド

- `npm audit --json`
- `./node_modules/.bin/eslint.cmd .`
- `node ./node_modules/typescript/bin/tsc --noEmit --pretty false`
- `npm run build`
- `git grep -n -I -E "(AIza ... |sk_live_ ... |PRIVATE KEY ... |AKIA ... |ghp_ ... )" -- .`
- `git ls-files .env .env.local .env.example .env.preview.local .vercel`

API ルート走査結果:

```
POST_ROUTES=17
SAME_ORIGIN=16
RATE_LIMITED=7
MISSING_SAME_ORIGIN:
src/app/api/auth/send-email/route.ts
```

5. 結果詳細

5.1 依存パッケージ監査

- `npm audit` は 0 vulnerabilities
- `postcss` は `package.json` の `overrides` で `^8.5.10` に固定
- `next build` との互換性問題は確認されていない

5.2 シークレット管理

- Git 管理下ファイルへの静的スキャンで典型的な秘密情報の混入は未検出
- `.env.local` と `.vercel/` は Git 管理対象外
- Git 管理下に残る環境変数ファイルは `.env.example` のみ

5.3 API 防御

- `POST` を持つ API ルートは 17
- そのうち 16 ルートで `requireSameOrigin()` を適用
- 7 ルートで `rateLimit()` を適用
- `auth/send-email` は `same-origin` ではなく署名 / JWT 検証ベースで保護

5.4 品質ゲート

- ESLint: 0 errors / 0 warnings
- TypeScript: 0 errors
- `next build`: 成功
- build warning 3 件は依存由来（`@auth0/nextjs-auth0` dpopUtils × 1、`jose` Edge Runtime × 2）で、現時点で出荷ブロッカーではない

6. 現行実装に即したセキュリティメモ

6.1 ローカル保存される補助状態

次の値はブラウザ `localStorage` に保存されます。

- ローソ一覧
- 先取積み立て一覧
- 個人目標一覧

- 徳ポイント用チケット価値
- 使用済みチケット数
- 固定費見直しの確認済み ID
- 固定費見直しの月別非表示 ID

評価:

- これらは UI 補助データであり、サーバー保存の主要家計データとは分離されている
- 同一ブラウザ依存であるため、共有端末利用時はブラウザプロファイルの分離が望ましい

6.2 Preview Deployment の扱い

- Vercel Preview Deployment はデモ / 検証環境として利用する
- 本番シークレットと Preview シークレットは分けて管理すること
- OAuth の Callback URL も Preview / Production を混同しないこと

6.3 ブラウザ互換

- `input[type="month"]` はブラウザ差異がある
- 専用ピッカー非対応時でも `YYYY-MM` 手入力で扱える運用にしている

7. コードセキュリティレビュー結果（2026-04-27）

ブランチ `kawaii0214` の差分に対して、以下の4候補を詳細分析しました。

候補	ファイル	判定	理由
AIプロンプトへの ユーザーデータ埋め込み	<code>src/app/api/ai/route.ts</code>	✓ 問題なし	同一ユーザーの自 データのみ対象。 AIプロンプトへのユ ーザーデータ埋め込 みは脆弱性非該 当
<code>JSON.parse</code> try/catch 欠如	<code>FoodLifestyleAssistant.tsx:251</code>	✓ 問題なし	Node.js 12+ で <code>__proto__</code> pollution 不可。 クラッシュは DoS 除外対象
<code>Puppeteer --no-sandbox</code>	<code>scripts/export-*.js</code>	✓ 問題なし	信頼済みローカル HTML のみ処理。 外部入力なし。ハ ードニング欠如は 脆弱性非該当

候補	ファイル	判定	理由
財務データの外部 AI API 送信	<code>src/app/api/ai/route.ts</code>	✓ 問題なし	認証済みユーザー自身の集計データ。PII・シークレット含まず。意図した機能

判定: 高信頼度の脆弱性 0 件

8. 残課題と所見

- `rateLimit` は全 POST API 一律ではないため、対象拡大の余地あり
- 依存由来の build warning は継続監視が必要
- 外部からの動的ペネトレーションテストは未実施
- ローカル保存データは端末依存であるため、将来的にはサーバー同期の設計余地がある

9. 総合判定

- 現在の確認範囲では `npm audit` 脆弱性は 0 件
- 重大な秘密情報の Git 混入は未検出
- build、型検査、Lint の品質ゲートは通過済み
- 総合評価は 93% で、本番運用に耐える高水準を維持している